



AI 驱动防御：从单点工具到持续化白帽能力

HackProve World 2026 白帽世界大会：中国·澳门

主题 02 讲义笔记

时间边界：00:06:45–00:11:52

核心主题：Collective Intelligence: The Union of AI and White Hat

素材依据：本主题 transcript、rel/abs SRT、官方参考池

目录

1	素材定位与问题意识	2
2	核心术语：本主题首次定义	2
2.1	Agent/代理	2
2.2	工具调用	3
2.3	AI 驱动防御	3
2.4	MCP 的边界预告	4
3	从单点工具到持续能力	4
3.1	单点工具的价值与天花板	4
3.2	持续化能力的结构	4
4	安全边界的新位置	5
4.1	边界从系统外壳进入行为过程	5
4.2	上下文成为新的攻防材料	5
5	工具调用链的防御指标	5
5.1	召回率与误报	5
5.2	工具调用链的可审计性	6
6	人机信任：白帽仍是闭环中的校准器	6
7	落地模型：AI 驱动防御闭环	7
7.1	四阶段流程	7
7.2	风险控制矩阵	7
8	与后续主题的衔接	7
9	总结	8
	配图接入	9
	官方参考	11

摘要

本讲义围绕大会开场中对 AI 时代安全边界的判断展开：AI 已经进入产品、工作流、企业决策，也进入攻防每个环节。主题 02 的任务，是把“AI 驱动防御”讲成一个可落地的安全能力模型：模型 M 、工具链 T_c 、白帽经验 H 、证据 E 与人工判断 J 共同构成持续化防御闭环。这里首次完整定义 Agent/代理、工具调用与 AI 驱动防御；MCP 只作为后续主题 05 的接口预告出现。

大会口播强调“信任必须被测试，必须被持续验证”。这句话是本讲义的主轴。AI 可以生成内容、代码和行动建议；安全团队真正需要管理的，是这些建议如何被授权、如何被工具执行、如何留下证据、如何接受白帽复核。单点扫描器像一把螺丝刀，能解决局部问题；持续化白帽能力更像一条带质检台的生产线，每一步都能复现、审计、迭代。

1 素材定位与问题意识

主题 02 的现场语境来自大会开场：本届主题为 *Collective Intelligence: The Union of AI and White Hat*。演讲者把未来安全描述为 AI 能力、白帽经验、自动化效率、人的判断、边界与责任的联合体。该判断直接引出一个工程问题：当 AI 进入攻防流程，防御侧怎样把一次性的工具使用，升级为可积累、可迭代、可审计的能力？

本主题的三层问题

1. **能力层**：AI 能协助发现、验证、报告和复盘安全问题，但能力本身需要边界。
2. **流程层**：工具调用链必须把输入、上下文、参数、输出和证据串起来。
3. **信任层**：人机协同需要持续验证。信任像桥梁承重测试，不能靠“看起来稳”来成立。

大会提到 DigPool AI 是面向白帽的 AI 渗透工具台，目标是让优秀白帽的经验、方法和判断沉淀为可积累、可迭代的 Agent 与 Skills。这里的关键词是“沉淀”：一次漏洞发现是事件，沉淀后的方法才是组织能力。白帽经验如果只停留在个人脑中，就像手艺人的诀窍；被结构化为任务分解、工具调用、验证规则与报告模板后，才像可复制的工艺流程。

2 核心术语：本主题首次定义

2.1 Agent/代理

Agent/代理是围绕目标进行多步推理、调用工具、维护状态并产出行动的系统组件。它通常包含四类要素：

- **目标**：要完成的安全任务，例如“验证某个接口是否存在权限绕过”。
- **上下文**：资产信息、历史记录、策略约束、用户指令、工具返回内容。
- **行动空间**：可调用的函数、API、命令、检索器、报告生成器、审计工具。

- **反馈回路：**工具输出、测试结果、人类审批、失败重试、证据归档。

用类比来说，普通聊天模型像坐在桌边的顾问，能给建议；Agent 像带着工作单和工具箱的现场工程师，能按步骤行动，还要把每次操作写入工单。Anthropic 官方材料把工作流与 Agent 做了区分：工作流常由预定义路径编排，Agent 则可根据反馈动态决定流程。¹

2.2 工具调用

工具调用是模型或 Agent 把自然语言意图转换为结构化函数、API、命令或插件动作的过程。它把“查一下这个域名的暴露面”翻译成可执行步骤，例如：

$$\text{intent} \rightarrow f_1(\text{asset}) \rightarrow f_2(\text{result}) \rightarrow f_3(\text{evidence})$$

更安全的表达方式是工具调用看成一条有约束的链：

$$C = \langle u, p, ctx, tool_i, args_i, out_i, e_i, approve_i \rangle_{i=1}^n$$

其中 u 是用户请求， p 是系统策略， ctx 是上下文， $tool_i$ 是第 i 个工具， $args_i$ 是参数， out_i 是输出， e_i 是证据， $approve_i$ 是必要审批。安全团队要关心的重点并非“能不能调用工具”这一点本身，重点在于调用是否被授权、参数是否合规、输出是否可验证、证据是否可回放。

OpenAI 官方关于 agents 的材料强调，构建 agent 需要工具、编排、观测，以及文件、网络、计算机使用等能力，并需要 tracing 来理解多 agent workflow 的执行路径。²

2.3 AI 驱动防御

AI 驱动防御是用模型 M 与工具链 T_c 辅助发现、验证、响应和复盘安全问题的体系。它强调三个特征：持续化、可审计、可回滚。可以用一个简化函数表示：

$$D = F(M, T_c, H, E, J)$$

其中 D 是防御能力， M 是模型， T_c 是工具链， H 是白帽经验， E 是证据， J 是人工判断。若缺少 E ，系统会变成“只会给结论的黑箱”；若缺少 J ，系统可能把高置信度误判包装成自动化行动；若缺少 H ，模型很难理解真实攻防中的灰度边界。

一句话定义

AI 驱动防御是把 AI 的推理与生成能力接入安全工具、白帽经验和审计证据，使漏洞发现、验证、报告、协同与复盘从单次动作变成持续运转的组织能力。

¹Anthropic, *Building effective agents*, <https://www.anthropic.com/engineering/building-effective-agents>.

²OpenAI, *New tools for building agents*, <https://openai.com/index/new-tools-for-building-agents/>.

2.4 MCP 的边界预告

MCP 将在主题 05 完整定义。本主题只保留边界预告：当 Agent 需要连接外部数据源、业务工具和开发环境时，需要一种统一的连接与描述层。这个连接层会带来便利，也会引出工具描述、凭证权限、上下文污染和跨 Agent 传播等风险。主题 02 只建立“为什么需要接口层”的直觉，机制细节留给主题 05。

3 从单点工具到持续能力

3.1 单点工具的价值与天花板

单点工具包括扫描器、模糊测试器、PoC 验证脚本、报告生成器、日志检索器等。它们像不同用途的仪表：电压表能测电压，温度计能测温度，单个仪表无法自动完成整车年检。安全工作同样如此，扫描结果需要去重，疑似漏洞需要复现，复现需要证据，证据需要进入报告和工单，工单还要进入修复、回归和复盘。

单点工具的天花板主要有四个：

1. **上下文断裂**：工具只看到局部输入，难以理解业务影响。
2. **证据断裂**：结果散落在终端、截图、日志和报告草稿中。
3. **经验断裂**：白帽的判断留在临场操作中，下一次难以复用。
4. **协同断裂**：发现、验证、报告、修复之间缺少统一状态。

3.2 持续化能力的结构

持续化白帽能力把工具组织成闭环。一个简化闭环如下：

发现 → 验证 → 分级 → 报告 → 修复跟踪 → 复盘沉淀 → 下一轮发现

AI 的位置可以理解为“流程放大器”。它能把模糊任务拆成步骤，把工具结果翻译成判断，把重复报告变成结构化草稿，把历史经验变成下一轮检查清单。放大器会同时放大信号和噪声，所以持续化系统必须配套验证、审计和人工接管。

白帽能力沉淀的三个载体

- **Agent**：保存任务目标、上下文状态和多步行动策略。
- **Skill**：保存可复用方法，例如资产枚举、漏洞复现、证据整理、报告写作。
- **Trace**：保存从输入到输出的执行轨迹，为复核与问责提供材料。

4 安全边界的新位置

4.1 边界从系统外壳进入行为过程

传统安全边界常围绕代码、接口、账号、权限、人员和基础设施展开。AI 进入产品和工作流之后，边界还会出现在 Agent 行为、Prompt 上下文、工具调用、技能编排与人机信任关系中。边界变得更像“交通规则”：道路本身要安全，车辆行为也要可控，驾驶员还要接受红绿灯和限速约束。

对防御侧而言，风险可用简化形式表达：

$$R = P(T | A) \times Impact$$

其中 A 是资产， T 是威胁， $P(T | A)$ 表示在给定资产条件下威胁发生的概率， $Impact$ 是影响。AI 驱动防御的目标，是降低发生概率、降低影响面，并提高发现与响应速度。

4.2 上下文成为新的攻防材料

Prompt 上下文可以包含用户需求、系统规则、文档片段、工具返回、历史对话和业务数据。它像会议桌上的资料夹：里面放了正确流程，Agent 才能做对事；里面混入误导信息，Agent 也可能沿着错误方向行动。本主题不展开 prompt injection 的完整定义，该定义留给主题 07；此处只强调上下文已经成为防御面的一部分。

因此，安全团队需要给上下文做“食品安全检查”：

- 来源是否可信；
- 内容是否与任务相关；
- 是否包含指向高风险动作的指令；
- 是否诱导工具越权、泄露凭证或跳过审批；
- 是否能在审计记录中追溯。

5 工具调用链的防御指标

5.1 召回率与误报

在漏洞发现中，召回率衡量系统找回真实问题的能力：

$$Recall = \frac{TP}{TP + FN}$$

TP 是真阳性， FN 是假阴性。召回率高意味着漏报少。若系统把大量无关问题也报出来， FP 假阳性会上升，白帽会被噪声拖垮。理想的 AI 驱动防御，需要在召回率、误报率、验证成本之间做平衡。

一个实用指标组合如下：

指标	符号	关注点	使用场景
召回率	$Recall$	少漏报	漏洞发现、日志告警、资产暴露面检查
精确率	$Precision = \frac{TP}{TP+FP}$	少误报	告警分诊、报告候选筛选
验证成本	$Cost_v$	人和机器消耗	PoC 复现、截图取证、人工审批
响应延迟	$Latency$	从发现到处置的时间	高危漏洞响应与修复跟踪

5.2 工具调用链的可审计性

若一个 Agent 调用了五个工具，最终给出“存在高危漏洞”的结论，审计者必须能回答：

1. 最初请求是什么，谁发起；
2. 每一步调用了哪个工具，参数是什么；
3. 哪些结果支持结论，哪些结果被排除；
4. 是否触发过高风险动作或人工审批；
5. 报告中的证据能否复现。

这可以写成证据聚合：

$$E = \{e_1, e_2, \dots, e_n\}, \quad Verdict = g(E, policy, human_review)$$

其中 g 表示分级与判断函数。没有证据集合 E ，报告很快会变成“模型这么说”；加入策略和人工复核后，结论才有工程意义。

6 人机信任：白帽仍是闭环中的校准器

大会口播给出一个尖锐判断：越自动化的系统，越需要人来验证边界；越强大的模型，越需要有人测试失控路径；越复杂的 Agent workflows，越需要有人证明它是否可信。这个判断的现实含义很直接：AI 可以提高速度，不能取消责任。

白帽在 AI 驱动防御中的角色可分为三种：

- **设计者**：把经验沉淀成 Skills、规则、测试模板和分级标准。
- **校准者**：检查模型输出，纠正误判，处理业务语境中的灰度问题。
- **审计者**：复核工具调用链、证据、审批和修复闭环。

直观地说，AI 像显微镜和机械臂的组合：显微镜放大细节，机械臂执行动作；白帽负责决定观察什么、动作是否合规、异常是否真的构成风险。若把三者混在一起，系统容易把“看见了异常”误当成“证明了漏洞”，把“能执行动作”误当成“应该执行动作”。

7 落地模型：AI 驱动防御闭环

7.1 四阶段流程

一个保守、可审计的 AI 驱动防御流程可分为四阶段：

1. **发现：** Agent 根据资产清单、历史漏洞和策略约束生成检查计划，调用低风险工具收集信号。
2. **验证：** 对候选问题执行最小化验证，记录参数、响应、截图、日志和失败路径。
3. **报告：** 将证据映射到影响、复现条件、修复建议和剩余风险。
4. **沉淀：** 把有效检查方法写回 Skill，把失败样例写入评估集，把误报原因写入过滤规则。

每个阶段都要设置“人类接管点”。比如读取公开页面可以自动执行，访问敏感内部系统、尝试破坏性 payload、读取凭证、修改配置、外发数据等动作必须进入审批或隔离环境。

7.2 风险控制矩阵

环节	主要风险	控制方式
任务拆解	目标漂移、过度扩展范围	固定授权边界，记录用户目标与禁止动作
上下文读取	混入误导内容或敏感信息	来源标注、上下文分区、敏感字段屏蔽
工具调用	越权、破坏性动作、参数污染	最小权限、参数校验、审批门禁、沙箱执行
结论生成	幻觉、证据不足、影响夸大	证据引用、复现实验、人工复核
经验沉淀	把误判写成规则	回归测试、版本化 Skill、失败样例保留

8 与后续主题的衔接

本主题建立三件事：Agent 是能行动的系统组件，工具调用是意图到机器动作的结构化转换，AI 驱动防御是模型、工具、白帽经验、证据和人工判断组成的持续化闭环。后续主题会沿着这条线继续展开：

- 主题 03 会把 AI 安全运营、治理环境和风险矩阵讲完整。
- 主题 05 会完整定义 MCP，并展开工具描述、凭证权限与 Agent 间传播风险。
- 主题 07 会完整定义 prompt injection、微调与数据投毒。
- 主题 09 会把审计链路与 Trace 作为 AI coding 行为治理的核心对象。

9 总结

AI 驱动防御的关键转变，是把“某个工具能做什么”提升为“一个组织能持续证明什么”。一次扫描能发现问题，一条可审计的工具调用链能解释问题；一次人工判断能完成复核，一套沉淀下来的 Skill 能让团队下次更快、更稳；一个 Agent 能执行任务，一套人机信任机制才能让执行结果进入生产级安全流程。

从单点工具到持续化白帽能力，核心路径可以压缩为：

工具 → Agent → Skill → Trace → 可信闭环

这也是大会主题中“AI 与白帽联合”的工程化含义。AI 提供速度、规模和生成能力；白帽提供经验、边界判断和责任校准；证据链把二者连接成可复盘、可协同、可迭代的防御系统。

配图接入

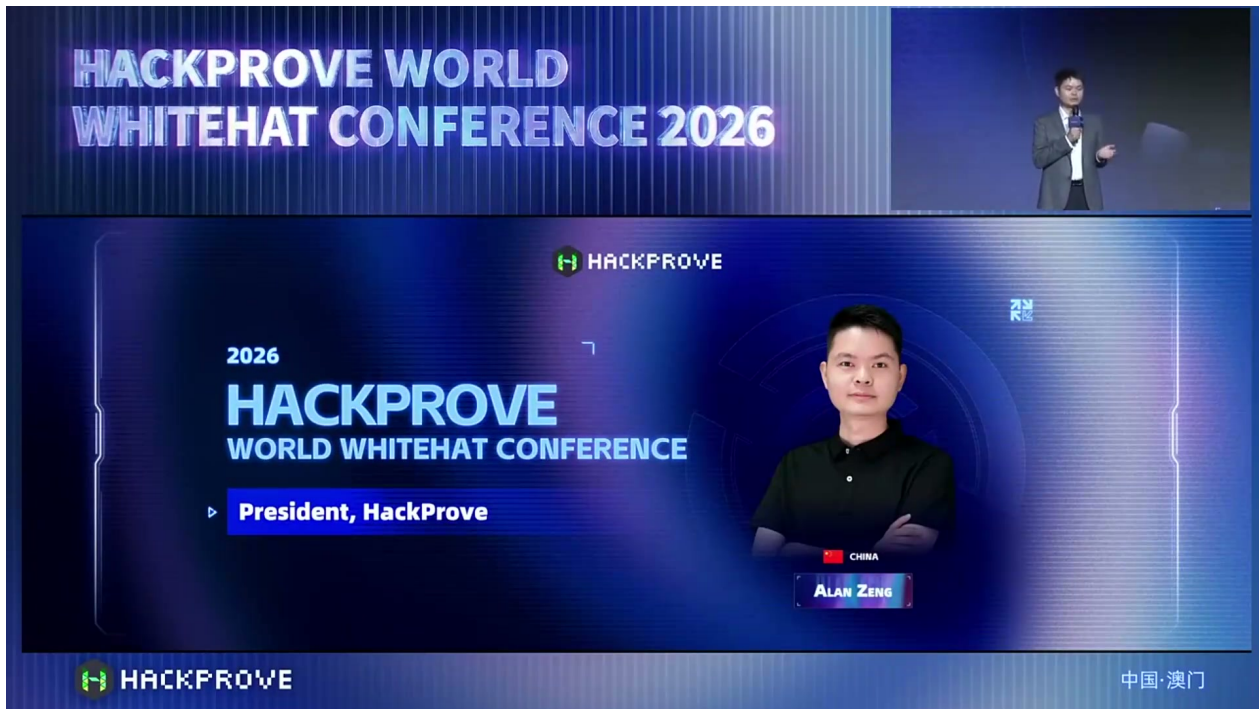


图 1: HackProve 主席引入白帽大会议程：该画面可作为 AI 驱动防御主题的组织入口，强调议题从个人工具使用扩展到大会级别的能力建设。⁴

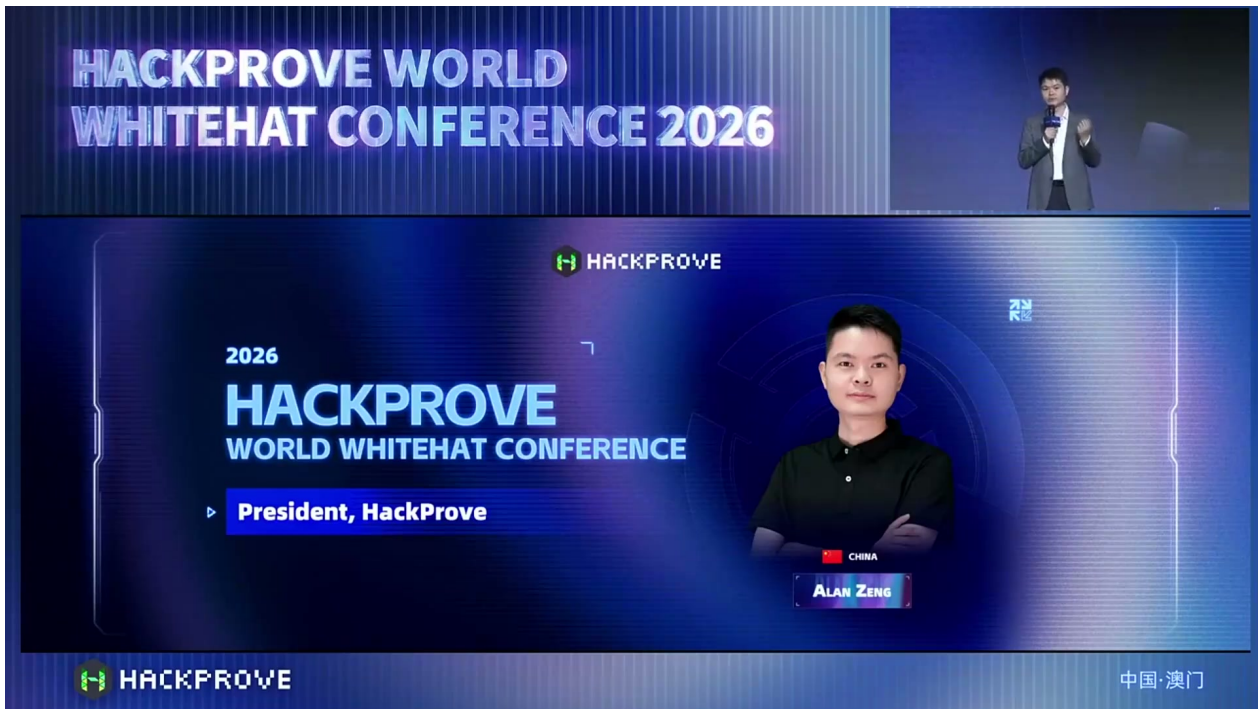


图 2: “Collective Intelligence: The Union of AI and White Hat” 主题页: 图像直接给出本节核心命题, 即 AI 系统与白帽经验的联合, 会把漏洞发现、验证、报告和协同连成持续流程。⁶



图 3: 报告写作自动化页面: 画面中的 “Drafting”、“risk ratings”、“remediation steps” 指向 AI 防御工具链的落地环节, 适合解释从原始工具输出到可审阅报告的转换。⁸

官方参考

1. OpenAI. *New tools for building agents*. <https://openai.com/index/new-tools-for-building-agents>
2. Anthropic. *Building effective agents*. <https://www.anthropic.com/engineering/building-effective-agents>